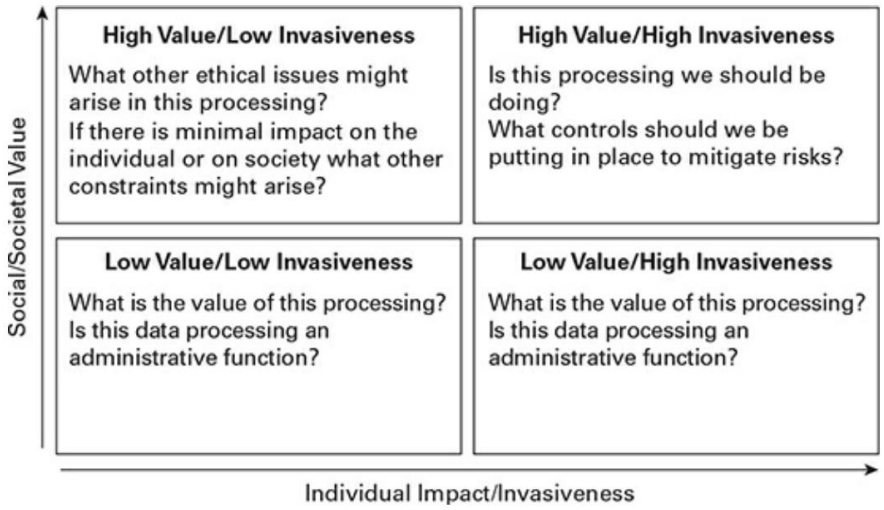
Activity 1

- Student name = **eamonn kelly**
- Student number = **D24127620**

Overview

O'Keefe and O'Brien's Invasiveness vs. Impact matrix



Activity Task –

- Consider the two examples and identify in which part of **O'Keefe and O'Brien's Invasiveness vs. Impact matrix** the technology fits into explaining your rationale.
- For each example think about what controls could be put in place to mitigates risks of invasive data processing.

Example 1 –

Health Monitoring App >> A national health app collects individuals' heart rate and location data to detect early signs of heart issues for individuals but also to track national trends of heart disease.

Classification

- this is **high value** and **high invasiveness**, placing it in the top right hand corner of the

- The data is highly sensitive and highly personal and inappropriate use or access by 3rd parties could have negative impact on user, such as insurance companies.
- **What** Data types present are:
    - **Medical**
        - Medical practitioners operate under an ethical presumption of confidentiality.
    - **Geo-location**
        - Is geo data required for medical analysis? Perhaps if there is a regional element? Needs to be clarified.
- **Where** is the data stored?
    - **Locally** on personal device
    - **Central storage** (national archive) - for access by medical practitioners, data scientists for processing and analyse
- **Who** requires access?
    - User will require some level of local data analysis, pre-processing, and presentation
    - Data Scientists / Medical practitioners – assessment of ECG data, pre-processing, statistical analysis.

Mitigation

- **Consent**
    - User needs to be explicitly informed of data usage and any possible risks associated with its usage.
    - Right for end user to disengage? Is it possible? How might that work?
- **Data Minimization**
    - Only required medical data needed for specific study to be made available to national archive.
- **Anonymization** -where should it be anonymized?
    - Identification is required to identify heart issues for individuals.
    - Anonymization could take place prior to transfer to national archive.
- **Access**
    - Should be strictly limited to the user, who can transfer or provide access as needed to any medical practitioners they wish
    - Include MFA
    - National Archive - use of RBAC – who is accessing the data and what level of access to they require?

        - Audited/logged access? this is perhaps too much overhead?
    - **Storage**
        - Encryption in transit
        - Encryption in storage?
            - Is the overhead to great?
    - **Auditing / Maintenance**
        - Logs kept of who is accessing the data, when.
        - Regular / periodic privacy impact assessments / risk assessments.
        - Impact and guidelines legally i.e. GDPR / AI Act
    - **End of Life**
        - Clear policy about what happens at end of project
            - All data deleted or maintained for some potential future analysis?
            - User notification of results?
            - User notification of deletion of data?
            - May not be possible if anonymized?

Example 2 –

- Retail Behaviour Tracking: A supermarket chain tracks customers' purchase as well as movement in-store through a digital loyalty card app to optimise shelf layouts and increase sales.

Classification

- this is **high value** and **low to high invasiveness**, placing it in the top **left** hand corner of the matrix, while it is not in the right hand side (RHS), it is moving towards the RHS.
- The data may be sensitive and personal, such as
    - medical supplies,
    - nutritional conditions
    - eating /drinking habits
    - inappropriate use or access by 3rd parties could have negative impact on user, such as increased health insurance premiums, affect particular jobs perhaps, so it is s still potentially invasive.
- **What** Data types present are:
    - **Purchase history**

        - All items purchased are tracked. Item, date, price, method of payment etc
        - If a user had security considerations such as military, police, political etc. routines, location could be determined by the data, which makes the data potentially quite sensitive.
        - Payment/credit card information – potential fraud
    - **Personal data**
        - What level of personal data is required?
            - Name, address, tel number?
            - Is ID required to apply for the scheme? If so is that stored/validated?
            - Is an app required to be installed on a personal phone?
                - What data is acquired from the phone? Make/model/OS details/network/geo location etc
    - **Geo-location**
        - Movement through the store – it is not clearly stated how this is carried out. Is it via in-store camera?
            - Use of facial recognition?
            - Is there a theft prevention aspect to this? i.e. some individuals being "barred" from the store due to history of theft?
            - Is it an anonymized volume count of aisle movement and sequencing?
- **Where** is the data stored?
    - **Locally** on store till and local store server?
    - **Central storage** (company HQ server)-
        - Is it a multinational -is it transferred internationally for regional purchasing analysis, supply chain analysis, Just in Time inventory analysis?
- **Who** requires access?
    - Do local in-store staff require access?
        - Can in-store staff validate a loyalty card and identification locally? Is that a requirement?
    - Data Scientists / company executives
        - Do executives have a need to access data from specific users or groups of users?
        - Data Scientists to pre-process/aggregate etc and visualize.

Mitigation

    - **Consent**

        - User needs to be informed of data usage and any possible risks associated with its usage.
        - If app on phone –
            - Level of push notifications
            - Data acquisition from phone?
            - Access to geo data on the phone?
        - For movement through the store should a sign be put in place that movement Is tracked via camera if anonymized? Is that sufficient? If data is kept, explicit permission to do so must be obtained.
    - **Data Minimization**
        - Clarity on whether data is minimized or not and at what stages? This is probably unlikely as the purpose is to build individual profiles, then group and target those profiles for upselling , or sell on the data.
    - **Anonymization** –
        - To what degree is this possible given the nature of the data usage?
    - **Access**
        - RBAC
            - Given the storage or personal details, name, address, tel, payment details data access needs to be strictly controlled
            - Not generally accessible
        - Include MFA
        - Audited/logged access? this is perhaps too much overhead?
    - **Storage**
        - Encryption in transit
            - Does any analysis need to be performed locally in-store?
            - Payment information needs to be encrypted in transit.
        - Encryption at rest?
            - As payment data is present this needs to be done.
    - **Auditing / Maintenance**
        - Access list – who accessed when
        - Regular / periodic privacy impact assessments / risk assessments.
        - Impact and guidelines legally i.e. GDPR / AI Act
    - **End of Life**
        - Clear policy about what happens at end of loyalty program?
            - Who owns the data?

- Can is be sold to some else without the users consent?
- Can it be sold to a 3rd party outside of the users> country or region?
- What types of companies can it be sold to ? i.e. insurance, health, security, marketing etc.
- Can a user request all their data or have it deleted i.e. remove themselves from the scheme?
- How long will the data be kept for? Is it effectively forever?